Udyam Digital: data privacy & security note

Accel Business SMB onboarding prototype · designed for the Digital Personal Data Protection (DPDP) Act, 2023 · all data in the prototype is synthetic

1. Principles we designed for

- **Consent before collection.** KYC cannot start until the owner accepts a plain-language notice (English / Hindi in the prototype; all 10 languages in the pilot). The notice says what we collect, why, how long we keep it and their rights. Consent is itemised: KYC (required), order updates (optional, on), marketing (optional, **off** by default).
- **Purpose limitation.** KYC data is used only to verify identity and address and to activate services. Marketing needs its own opt-in and never reuses KYC fields.
- **Data minimisation.** The advisor asks only 8 business questions (no personal ID). KYC asks only for the 4 documents the telecom process needs. The GSTIN/Udyam lookup pre-fills data, so less is typed and stored.
- **Easy withdrawal.** "Withdraw consent & erase my data" is one tap on the consent screen. It deletes uploaded-document fields and KYC results and logs the event.

2. What we collect, where it lives and for how long

Data	Why	Where / how	Retention
Business profile (type, city, size, needs)	Recommend a bundle	Session record (SQLite)	30 days if no order; contract period if ordered
Document images (GST, Udyam, ID, bill)	Extract fields	**Memory only**, never written to disk or logs	Discarded right after extraction
Extracted fields (names, numbers, address)	Run KYC checks	Session, server side	**Erased right after verification**; only masked values kept
KYC result (pass/fail per check, masked GSTIN/ID)	Audit, activation	Session + order	Contract + 8 years (licence / tax rules), then deleted
Name, mobile (order / callback)	Installation, updates	Order record, phone stored masked + last 4 digits	Contract period
Consent receipts & audit events	Prove lawful processing	Append-only audit table (no raw IDs)	As long as the related data + 1 year

3. Security controls in the prototype

- **Masking everywhere:** GSTIN shown as 27XXXXXXXX7D1ZP, ID as XXXXXXXXX7889, phone as XXXXXX3210, on screen, in the back-office and in logs.
- **No identifiers in URLs:** registry lookups use POST bodies, so GSTIN/Udyam never reach access logs, browser history or referrers. HTTP access logging is off and app logs print masked values only.
- **Tracker access** needs the order ID *and* the last 4 digits of the registered mobile.
- **Back-office** sits behind a PIN (demo). In production: SSO + role-based access, so partners see only leads routed to them.
- **LLM use is optional and minimal:** without a key everything runs locally (rules + on-device OCR). With a key, only chat text is sent, with no customer IDs added. Document images stay on the server unless the operator opts in (KYC_USE_LLM). Production would use an India-region enterprise endpoint with no-training/zero-retention terms.
- **Deterministic decisions:** eligibility, pricing and KYC pass/fail are rule-based and explainable. The LLM only converses and explains, so no automated decision rests on an opaque model.
- **Browser hardening:** nosniff, no-referrer and a camera/mic permissions policy. Uploads are capped at 8 MB and must be images.

4. Data-principal rights & governance

- Access, correction and erasure via the app or the grievance officer (grievance@accel.example). A nominee can be registered with the grievance officer. Breach notification to the Data Protection Board and affected users per DPDP rules.
- Children's data is not collected (business owners only). Cross-border transfer: none required; the LLM provider would be selected for India-region processing.
- **Production hardening (pilot):** TLS everywhere, encryption at rest (KMS), real DigiLocker pull with consent artefact, Aadhaar e-sign via a licensed ESP, VAPT before launch, DPIA, and quarterly access reviews for partner logins.

Prototype implementation references: backend/main.py (consent, masking, erasure, audit), backend/kyc.py (checks), backend/ocr.py (in-memory processing), backend/db.py (what is stored).